

Řízení informační bezpečnosti

Kamil Malinka

(využity materiály Doc. Staudka a konzultace Prof. Matyáše)

Verze: podzim 2026

organizace předmětu

Od techniky k řízení odpovědnosti

Technická opatření jsou základ. Tento předmět řeší prostředí, ve kterém mají dávat smysl, fungovat a být doložitelné.

TECHNICKÝ ZÁKLAD

Umíme zabezpečit server

šifrování · síť · hardening
autentizace · monitoring · secure coding

tohle řeší hlavně technické předměty



PV017 · ŘÍZENÍ BEZPEČNOSTI

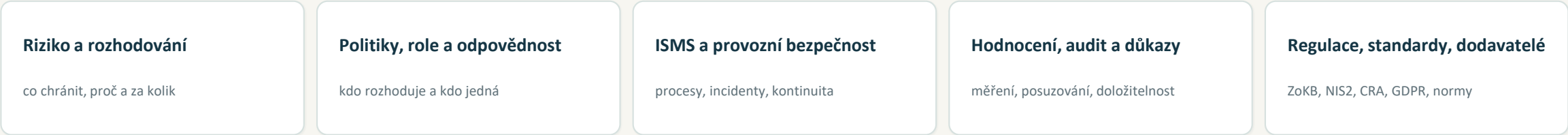
Ale...

1. Co je pro organizaci přijatelné riziko?
2. Kdo rozhodne a kdo za rozhodnutí odpovídá?
3. Jaké politiky a procesy to vynucují?
4. Co po nás chtějí NIS2, ZoKB, CRA a GDPR?
5. Jak prokážeme, že bezpečnost opravdu funguje?

PV017 je o řízení bezpečnosti: od rizika přes provoz až k regulaci a důkazu.

Kam v semestru půjdeme

Technické kontroly jsou nezbytné, ale samy o sobě nestačí. PV017 se dívá na systém okolo nich: rizika, odpovědnost, právo, provoz, standardy a důkazy.



SEMESTRÁLNÍ TRASA

P1	P2 · P4 · P6	P3 · P8 · P9 · P12	P5 · P7 · P10 · P11
Jazyk bezpečnosti	Řízení a odpovědnost	Regulace a standardy	Praxe a důkaz
bezpečnost, informace, základní pojmy	rizika, politiky, role, ISMS	ZoKB, NIS2, CRA, GDPR, normy	provoz, aplikace, hodnocení, posuzování

Ať budete vyvíjet, provozovat, navrhovat architekturu nebo řídit IT, netechnický kontext bezpečnosti vás dožene.

Co si odnést?

Bezpečnost se posunula z otázky „umíme to nastavit?“ k otázce „umíme to řídit, doložit a nést odpovědnost?“

PV017 přidává schopnost rozhodovat o riziku, navrhnout řídicí rámec, připravit organizaci na regulaci a vysvětlit bezpečnost managementu.

Proč právě teď?

NIS2

širší záběr, reporting incidentů, odpovědnost vedení

ZoKB

česká implementace NIS2 je účinná od 1. 11. 2025

CRA

bezpečnost produktů s digitálními prvky po celý životní cyklus

Dopadne to na architekty, vývojáře, provoz, bezpečnostní týmy i vedení. Každý IT profesionál bude muset rozumět i netechnickému kontextu.

Organizace předmětu

Základní rytmus semestru a hodnocení.

- 01** ————— **12x 2h přednášek**
výklad, kontext, praktické perspektivy
- 02** ————— **Polosemestrální zkouška (30b.) – testové otázky – proběhne 3.11. v rámci přednášky, 2-3 skupiny**
průběžné ověření znalostí
- 03** ————— **Závěrečná písemka (70b.) – kombinace otevřených a testových otázek**
hlavní část hodnocení
- 04** ————— **Vše bude vypsáno v IS**
formální informace a termíny

Obsah předmětu - přednášek

Přednášky #1–#4

Přednáška #1 (Malinka)

Co se rozumí bezpečností a informační bezpečností zvláště
Základní pojmy
Dosahování informační bezpečnosti

Přednáška #2 (Malinka)

Co se rozumí řízením rizik – stručně
Politiky jako specifikátory toho, co a jak dělat
Kdo má v instituci na starosti dosažení informační bezpečnosti

Přednáška #3 (Loutocký)

Přístup k regulaci kybernetické bezpečnosti
Legislativní rámec

Přednáška #4 (Stupka)

Role řízení kybernetické bezpečnosti

Obsah předmětu - přednášek

Přednášky #5–#8

Přednáška #5 (Kumpošt)

Jak zajistit provozní bezpečnost – pohled z praxe

Přednáška #6 (Malinka)

ISMS - systém procesů zajišťující kontinuální efektivitu zabezpečování

Přednáška #7 (Matyáš + Malinka)

Jak hodnotit bezpečnost,
Jak významná je role standardů, bez nich ani ránu

Přednáška #8 (Malinka)

Polosemestrální písemka

Obsah předmětu - přednášek

Přednášky #9–#12

Přednáška #9 (Loutocký)

Právní rámec kybernetické bezpečnosti (ZoKB, NIS 2, CRA, GDPR)

Přednáška #10 (Stecko)

Jak zajistit aplikační bezpečnost – pohled z praxe

Přednáška #11 (Sedláček)

Praktické poznatky z posuzování kyberbezpečnosti – pohled z praxe

Přednáška #12 (Kasl)

Certifikace, sdílení dat, dodavatelské řetězce a další nové výzvy regulace

Závěr semestru klade důraz na právo, aplikační bezpečnost, posuzování a nové regulační výzvy.